

RISHI VARTHINI

192421304

ITA1407 ETHICAL HACKING

Question 1 :

A mid-sized financial organization operates several legacy Windows servers where multiple RPC services remain exposed due to delayed patching cycles caused by operational constraints. Recently, abnormal traffic patterns and unauthorized connection attempts have been observed within the internal network. As a security analyst, evaluate how attackers could exploit these RPC vulnerabilities to gain unauthorized access and escalate privileges. Assess the level of risk associated with delaying patches in such environments and justify whether immediate patch deployment or controlled maintenance scheduling is more appropriate. Recommend suitable mitigation strategies to reduce exposure without affecting business continuity.

Introduction

Remote Procedure Call (RPC) allows communication between systems and applications on a network. Legacy Windows servers with exposed and unpatched RPC services can become targets for attackers seeking unauthorized access.

Vulnerability Analysis

Attackers can scan the network to identify exposed RPC ports and outdated services. By exploiting known RPC vulnerabilities, they may gain remote access, execute malicious code, escalate privileges, and move laterally across the network. This can lead to unauthorized access to sensitive financial data and critical systems.

Attack Process

1. Reconnaissance – Identify exposed RPC services.
2. Exploitation – Use known vulnerabilities to gain access.
3. Privilege Escalation – Obtain administrator privileges.
4. Lateral Movement – Access other internal systems.
5. Persistence – Install backdoors for long-term access.

Risk Assessment

Risk Area	Impact
Confidentiality	Exposure of financial data and credentials
Integrity	Modification of records and configurations
Availability	Service disruption and ransomware attacks

Business Impact	Financial loss and reputational damage
-----------------	--

The overall risk level is High to Critical due to delayed patching and publicly available exploits.

Immediate Patching vs Maintenance Scheduling

Immediate patching reduces security risks quickly but may cause service interruptions. Controlled maintenance allows testing and reduces downtime but leaves systems exposed for longer. A risk-based approach is recommended, where critical patches are deployed immediately after testing.

Mitigation Strategies

- Network segmentation to isolate legacy servers.
- Restrict RPC traffic using firewalls.
- Deploy IDS/IPS for threat detection.
- Apply least-privilege access controls.
- Conduct regular vulnerability assessments.
- Monitor logs and network activity continuously.
- Maintain secure backups for recovery.

Conclusion

Exposed RPC services create significant security risks. Implementing timely patching, network segmentation, monitoring, and access controls can reduce the likelihood of unauthorized access while maintaining business continuity.

Question 2

A web application used for online transactions suffers from multiple vulnerabilities, including cross-site scripting (XSS), cross-site request forgery (CSRF), and weak session management practices. Users report unauthorized transactions and session hijacking incidents. Evaluate how attackers could combine these vulnerabilities to execute complex attacks affecting user accounts. Assess the risks associated with poor session handling and lack of input validation. Justify the need for a layered security approach and recommend comprehensive mitigation strategies to secure the application.

Introduction

Web applications handling financial transactions must ensure confidentiality, integrity, and availability of user data. In this scenario, the application suffers from Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), and weak session management vulnerabilities. These weaknesses can be combined by attackers to compromise accounts and perform unauthorized transactions.

Vulnerability Analysis

Cross-Site Scripting (XSS)

XSS occurs when user input is not properly validated before being displayed in a webpage. Attackers inject malicious JavaScript that executes in the victim's browser.

Possible consequences:

- Theft of session cookies.
- Credential harvesting.
- Redirection to malicious websites.
- Unauthorized actions on behalf of users.

Cross-Site Request Forgery (CSRF)

CSRF tricks authenticated users into performing actions without their knowledge.

Examples:

- Unauthorized money transfers.
- Password changes.
- Account modifications.

Weak Session Management

Weak session controls allow:

- Session hijacking.
- Session fixation.
- Reuse of stolen session IDs.
- Unauthorized account access.

Attack Scenario

An attacker injects malicious JavaScript using an XSS vulnerability. When a user visits the infected page, the script steals the user's session cookie. The attacker then uses the stolen session to gain account access and performs unauthorized financial transactions through a CSRF attack.

Risk Assessment

Confidentiality

Sensitive customer data may be exposed.

Integrity

Transaction records and account information may be modified.

Availability

Services may be disrupted through malicious activities.

Business Impact

- Financial losses.
- Customer distrust.
- Regulatory penalties.
- Reputation damage.

Mitigation Strategies

- Validate and sanitize all user inputs.
- Use output encoding to prevent script execution.
- Implement CSRF protection tokens.
- Use Secure and HttpOnly cookies.
- Enable session expiration and inactivity timeouts.
- Deploy Multi-Factor Authentication (MFA).
- Implement a Web Application Firewall (WAF).
- Conduct regular penetration testing.

Conclusion

A layered security approach combining secure coding, session protection, and continuous monitoring is necessary to prevent account compromise and unauthorized transactions.

Question 3

An enterprise uses an outdated IIS server to host multiple internal and external applications, and recent vulnerability scans indicate several unpatched critical flaws. Despite warnings, the organization delays updates due to fear of downtime and service disruption. Assess how attackers could exploit these vulnerabilities to gain unauthorized access or execute remote code. Evaluate the risks associated with delaying security updates in such environments and justify whether immediate patching or temporary isolation is more appropriate. Recommend strategies to ensure both security and service availability.

Introduction

Internet Information Services (IIS) is a widely used web server platform. Outdated IIS servers often contain publicly known vulnerabilities that can be exploited by attackers to compromise systems and applications.

Vulnerability Analysis

Attackers may exploit:

- Remote Code Execution vulnerabilities.
- Authentication bypass flaws.
- Directory traversal attacks.
- File upload vulnerabilities.
- Misconfigured web services.

The attack process typically includes:

1. Identifying the IIS version.
2. Matching known vulnerabilities.
3. Executing exploit code.
4. Obtaining unauthorized access.
5. Installing malware or backdoors.

Risk Assessment

Confidentiality

Sensitive customer and business information may be exposed.

Integrity

Web content and databases can be modified.

Availability

Servers may be crashed or encrypted by ransomware.

Business Impact

- Financial losses.
- Compliance violations.
- Service downtime.
- Reputational damage.

Immediate Patching vs Temporary Isolation

Immediate Patching

Advantages:

- Eliminates known vulnerabilities.
- Reduces attack surface.

Disadvantages:

- Potential service interruptions.
- Compatibility concerns.

Temporary Isolation

Advantages:

- Reduces exposure while testing patches.
- Maintains operational continuity.

Disadvantages:

- Vulnerabilities remain present.

Recommendation

Critical vulnerabilities should be patched immediately after testing. If patching cannot occur immediately, isolate affected servers and restrict access until updates are deployed.

Mitigation Strategies

- Regular patch management.
- Network segmentation.
- Web Application Firewall deployment.
- Vulnerability scanning.
- Security monitoring.
- Backup and disaster recovery planning.

Conclusion

Timely patch management combined with isolation and monitoring significantly reduces the risk posed by outdated IIS servers.

Question 4

A mobile application used by customers stores sensitive information such as login credentials and personal data in plaintext within the device storage. Additionally, the

application communicates with backend servers over unsecured channels. Evaluate how attackers could exploit these weaknesses through device compromise or network interception. Assess the potential impact on user privacy and organizational reputation. Justify the need for encryption and recommend secure storage and communication techniques.

Introduction

Mobile applications frequently process sensitive customer information. Storing data in plaintext and using insecure communication channels significantly increases the risk of unauthorized access and data theft.

Vulnerability Analysis

Plaintext Data Storage

Attackers who gain access to a device can retrieve:

- Usernames and passwords.
- Personal information.
- Financial details.
- Authentication tokens.

Insecure Communication

Without encryption, attackers can intercept traffic using:

- Man-in-the-Middle (MITM) attacks.
- Rogue Wi-Fi networks.
- Packet sniffing tools.

Attack Scenario

An attacker creates a malicious Wi-Fi hotspot and intercepts communication between the application and backend servers. Since data is transmitted without encryption, sensitive information is captured and misused.

Risk Assessment

Confidentiality

Customer information becomes accessible to attackers.

Integrity

Attackers may alter transmitted information.

Availability

Services may be disrupted through network attacks.

Business Impact

- Customer trust loss.
- Legal liabilities.
- Regulatory fines.
- Reputational damage.

Mitigation Strategies

Secure Storage

- Use Android Keystore and iOS Keychain.
- Encrypt sensitive information.
- Avoid storing passwords in plaintext.

Secure Communication

- Enforce HTTPS/TLS encryption.
- Implement certificate pinning.
- Use secure API authentication.
- Validate server certificates.

Recommendation

Encryption should be applied both to stored data and network communications to ensure end-to-end protection.

Conclusion

Strong encryption and secure storage practices are critical for protecting customer information and maintaining organizational trust.

Question 5

A system administrator disables the Windows firewall temporarily to troubleshoot connectivity issues but forgets to re-enable it. Within a short period, multiple unauthorized access attempts are detected. Evaluate how attackers could exploit this temporary exposure to gain access to critical services. Assess the risks associated with mismanagement of security controls and justify the importance of enforcing automated policies. Recommend administrative safeguards to prevent such incidents.

Introduction

The Windows Firewall is an essential security mechanism that restricts unauthorized network access. Disabling it exposes systems to various cyber threats and significantly increases the attack surface.

Vulnerability Analysis

When the firewall is disabled, attackers can:

- Scan open ports.
- Access exposed services.
- Exploit vulnerable applications.
- Perform brute-force attacks.
- Install malware and ransomware.

Attack Scenario

An attacker identifies exposed services through network scanning. Weak or vulnerable services are exploited, providing unauthorized access to critical systems. The attacker may then move laterally through the network and compromise additional resources.

Risk Assessment

Confidentiality

Sensitive information may be exposed.

Integrity

System configurations and data may be modified.

Availability

Critical services may become unavailable.

Business Impact

- Financial losses.
- Operational disruption.
- Compliance violations.
- Reputation damage.

Importance of Automated Policies

Human error is a common cause of security incidents. Automated policies ensure that:

- Firewalls are re-enabled automatically.

- Security controls remain active.
- Alerts are generated when controls are disabled.

Mitigation Strategies

Administrative Controls

- Change management procedures.
- Security approval workflows.
- Periodic audits.
- Administrator training.

Technical Controls

- Automated firewall restoration.
- Centralized policy management.
- Intrusion detection systems.
- Continuous monitoring.

Recommendation

Organizations should implement automated security policies and centralized management systems to prevent accidental disabling of critical controls.

Conclusion

Proper management of security controls is essential for maintaining a secure environment. Automated enforcement, monitoring, and administrative safeguards help prevent unauthorized access and reduce organizational risk.

.